

GUÍA METODOLÓGICA DETALLADA

Aplicación y Análisis de la Encuesta Integral de Ciberseguridad

Versión: 1.0

Fecha: Enero 2026

Audiencia: CISOs, Auditores, Consultores de Ciberseguridad, Equipos de Gobernanza

TABLA DE CONTENIDOS

1. Propósito y Alcance
2. Preparación Pre-Encuesta
3. Ejecución de la Encuesta
4. Análisis de Respuestas
5. Cálculo de Métricas
6. Generación de Reportes
7. Roadmap de Mejora
8. Seguimiento y Evolución

1. PROPÓSITO Y ALCANCE

1.1 Objetivos de la Metodología

La encuesta integral de ciberseguridad busca:

9.
Diagnóstico Objetivo: Evaluar madurez actual de programa de ciberseguridad contra estándares internacionales (BSIMM15, NIST CSF 2.0, IMC-INCIBE).
10.
Identificación de Brechas: Detectar áreas críticas donde la organización está por debajo de baseline regulatorio (especialmente NIS2, GDPR, ENS).
11.
Cuantificación de Riesgo: Traducir hallazgos a métricas: % de controles operativos, MTTR, cobertura, etc.
12.
Roadmap Priorizado: Generar plan de acción con secuencia clara: quick wins, baseline compliance, advanced maturity.
13.
Benchmarking: Comparar posición con peers (si datos disponibles) y estándares globales.

14.

Governance Data: Proveer datos a dirección para decisiones de inversión en ciberseguridad.

Diagnóstico Objetivo: Evaluar madurez actual de programa de ciberseguridad contra estándares internacionales (BSIMM15, NIST CSF 2.0, IMC-INCIBE).

Identificación de Brechas: Detectar áreas críticas donde la organización está por debajo de baseline regulatorio (especialmente NIS2, GDPR, ENS).

Cuantificación de Riesgo: Traducir hallazgos a métricas: % de controles operativos, MTTR, cobertura, etc.

Roadmap Priorizado: Generar plan de acción con secuencia clara: quick wins, baseline compliance, advanced maturity.

Benchmarking: Comparar posición con peers (si datos disponibles) y estándares globales.

Governance Data: Proveer datos a dirección para decisiones de inversión en ciberseguridad.

1.2 Principios Metodológicos

Principio	Aplicación
Objetividad	Basarse en evidencia documentada, no percepciones.
Medibilidad	Toda respuesta debe mapear a métrica cuantificable (% / days / €).
Pragmatismo	Enfoque en lo que la organización realiza actualmente, no aspiraciones teóricas.
Constructividad	Encuesta como herramienta de mejora, no castigo ni auditoría punitiva.
Escalabilidad	Aplicable a cualquier tamaño de organización: PYME a multinacional.
Integralidad	Cobertura de todo el stack: governance, técnica, operativa, cumplimiento.

1.3 Stakeholders Clave

Rol	Responsabilidad
CISO/Director Seguridad	Liderazgo, coordinación, validación de datos.
Responsable Risk Management	Datos sobre análisis riesgos, vulnerabilidades, FAIR.
Head of Ops/Infrastructure	Penetesting, SIEM, logging, patch management.
Head of Development	SAST/DAST, SCA, secure coding practices.
Head of IT/Compliance	Auditoría, ISO 27001, NIS2, GDPR compliance.
HR/Training	Datos capacitación, phishing testing, onboarding.
CFO/Finance	Presupuesto, ROI de inversiones seguridad.
Asesor Legal/Externo	Interpretación normativa (NIS2, ENS, GDPR).

2. PREPARACIÓN PRE-ENCUESTA

2.1 Planificación (2-4 semanas antes)

Paso 1: Definir Alcance

- ¿Aplica la encuesta a toda la organización o divisiones específicas?
- ¿Se incluyen sistemas legacy, cloud, terceros?
- ¿Nivel de detalle: ejecutivo o granular?

Paso 2: Identificar Respondentes

Rol	Módulos	Tiempo
CISO	A, B, F	1.5 h
Dir. Operaciones	C, D	1.0 h
Dir. Desarrollo	C (SAST), B (SCA)	0.5 h
Head Compliance	F	0.5 h
Head Training	E	0.5 h
Auditor Interno	F, validación general	1.0 h

Paso 3: Recopilación de Documentos Base

Antes de comenzar, recopilar:

- Últimos reportes de auditoría (interna, externa, ISO).
- Políticas de seguridad (existentes o borradores).
- Reportes de pentesting (últimos 3 años).
- Documentación SIEM (rules, alerts, MTTD).
- Métricas de capacitación (% compliance, phishing rates).
- Mapa de vulnerabilidades actuales (CVSS distribution).
- Plan de continuidad y recuperación.
- Documentos NIS2/GDPR (si existen).

Paso 4: Socialización

- Comunicar objetivo: "Esta encuesta nos ayuda a entender dónde estamos y dónde queremos ir; no es revisión punitiva."
- Enfatizar confidencialidad: datos usados internamente, con dirección.
- Establecer timeline: fecha inicio, fecha límite respuestas.

2.2 Configuración Técnica

Herramientas Recomendadas:

- Google Forms / Microsoft Forms: Para recolección de datos (fácil, integración).
- Excel / Google Sheets: Para análisis y scoring (fórmulas automáticas).
- Power BI / Tableau / Google Data Studio: Para visualización.
- Jira / Azure DevOps: Para tracking de acciones de mejora.

Plantilla de Respuesta (Excel):

Módulo	Pregunta #	Pregunta	Respuesta (L0-L5)	Evidencia (link/doc)	Notas
A	A.1	¿Existe política?	L3	[Link política]	Última revisión 2024
A	A.2	¿Roles y RACI?	L2	[RACI draft]	Requiere aprobación DIR

2.3 Entrenamiento de Facilitadores

Si la encuesta será aplicada por múltiples auditores/consultores:

Sesión de Calibración:

- Revisar definiciones de cada nivel (L0-L5).
- Discutir qué evidencia es válida para cada nivel.
- Resolver ambigüedades en preguntas.
- Practicar con 2-3 preguntas de muestra.

Duración: 2-3 horas.

3. EJECUCIÓN DE LA ENCUESTA

3.1 Fases de Ejecución

Fase 1: Kickoff Interno (1 día)

- Reunión de CISO con stakeholders clave.
- Revisión de agenda: módulos, timeline, responsables.
- Distribución de encuesta y documentación.
- Establecer Q&A channel (email/Slack) para dudas durante proceso.

Fase 2: Recopilación de Datos (5-10 días)

Por Módulo:

Módulo	Responsable	Datos Clave a Recopilar
A (Governance)	CISO	Actas comité, presupuesto, políticas, matriz RACI
B (Risk & Vuln)	Risk/Security	Risk assessments, scanning reports, CVSS/EPSS data, patch SLAs
C (Pentesting)	Ops/AppSec	Reportes pentesting, remediation tracking, validation logs
D (SIEM)	SOC/Ops	SIEM config, rules, alert stats, MTTD, ingestion rates
E (Training)	HR/Security	Capacitación data, phishing rates, compliance %, knowledge test scores
F (Compliance)	Compliance/Legal	Auditoría reports, ISO certs, NIS2 assessment, BCP docs

Paso Práctico para cada Pregunta:

15. Leer enunciado con cuidado.
16. Seleccionar nivel (L0-L5) que mejor refleja estado actual (no ideal).
17. Anotar evidencia específica: documento, métrica, fecha.
18. Resolver dudas con CISO o facilitador.
19. Documentar excepciones (ej: "Nivel L3 en producción, L1 en development legacy").

Ejemplo de Respuesta Detallada:

Pregunta B.1: ¿Se realiza análisis formal de riesgos de ciberseguridad al menos anualmente?

Respuesta: L3 (Análisis anual formal)

Evidencia:

- Risk assessment document: [filepath] fechado enero 2025
- Metodología: NIST (RMF), con matriz de amenazas, vulnerabilidades, impacto
- Última auditoría: interna febrero 2025, sin críticos pendientes
- Frecuencia: anual, revisión post-incidente si aplica

Métrica asociada:

- Riesgos críticos identificados: 12
- Riesgos altos: 34
- Riesgos medios: 78

Notas:

- Falta cuantificación FAIR (probabilidad × magnitud €); es oportunidad L4
- Risk appetite no formalmente documentado; recomendación: L4 2026

3.2 Validación de Respuestas (2-3 días)

Paso 1: Auto-Revisión

- Respondente revisa su propia respuesta.
- Confirma que nivel elegido refleja realidad, no deseo.
- Valida que evidencia es correcta y accesible.

Paso 2: Revisión Cruzada

- CISO o auditor externo revisa respuestas de otros módulos.
- Busca inconsistencias (ej: "Risk management L3 pero vulnerabilidades no se priorizan").
- Valida que nivel elegido es soportado por evidencia (no inflado).

Paso 3: Ajuste y Calibración

- Reunión de 30 min con respondentes si hay discrepancias.
- Resolver diferencias: si hay desacuerdo, documentar motivo.
- Final answer: CISO/auditor asigna nivel final.

3.3 Registro de Datos

Estructura de Excel:

```
| ID | Módulo | Pregunta | Pregunta_Texto | L0 | L1 | L2 | L3 | L4 | L5 |
Respuesta_Final | Evidencia | Respondente | Validador | Fecha |
|----|-----|-----|-----|-----|-----|-----|-----|-----|-----|
| A1 | A | 1 | ¿Existe política? | ( ) | ( ) | ( ) | (X) | ( ) | ( ) | L3 | [link] |
CISO | Auditor | 15/1/26 |
| A2 | A | 2 | ¿Roles RACI? | ( ) | ( ) | (X) | ( ) | ( ) | ( ) | L2 | [link] | CISO |
Auditor | 15/1/26 |
```

4. ANÁLISIS DE RESPUESTAS

4.1 Tabulación y Scoring

Paso 1: Convertir Niveles a Puntuaciones

Nivel	Puntuación
L0	0
L1	20
L2	40
L3	60
L4	80
L5	100

Paso 2: Cálculo por Módulo

Ejemplo Módulo A (Governance, 12 preguntas):

A.1: L3 = 60
A.2: L2 = 40
A.3: L3 = 60
A.4: L2 = 40
A.5: L2 = 40
A.6: L3 = 60
A.7: L2 = 40
A.8: L3 = 60
A.9: L2 = 40
A.10: L3 = 60
A.11: L2 = 40
A.12: L3 = 60

Suma: 600

Promedio: $600 / 12 = 50$

Interpretación Módulo A: L2-L3 (Establecido, transición a Operativo)

Paso 3: Score Global

Con ponderación por módulo:

Módulo A (Governance, 20%): $50 \times 20\% = 10$
Módulo B (Risk & Vuln, 20%): $52 \times 20\% = 10.4$
Módulo C (Pentesting, 15%): $71 \times 15\% = 10.65$
Módulo D (SIEM, 20%): $58 \times 20\% = 11.6$
Módulo E (Training, 15%): $48 \times 15\% = 7.2$
Módulo F (Compliance, 10%): $62 \times 10\% = 6.2$

SCORE GLOBAL: $10 + 10.4 + 10.65 + 11.6 + 7.2 + 6.2 = 56.05$

Interpretación: L2-L3 (Básico a Operativo)

Clasificación: MADUREZ MEDIA, requiere aceleración hacia L3 completo

4.2 Análisis Cualitativo

Paso 1: Fortalezas (L3+)

Listar preguntas con L3 o superior:

- A.1: Política formalizada ✓
- A.6: Presupuesto aprobado ✓
- D.1: SIEM maduro ✓

Paso 2: Brechas Críticas (L0-L1)

Listar preguntas con L0-L1:

- B.13: FAIR cuantificación (L1) → riesgo en € desconocido
- E.5: Medición efectividad training (L1) → ROI training opaco
- F.3: Preparación NIS2 notificación (L1) → riesgo compliance alto

Paso 3: Debilidades Sistémicas (Patrón en módulo)

Ejemplo:

- **Módulo B completamente L1-L2:** vulnerabilidades no se priorizan bien, CVSS/EPSS no usados, SCA parcial.
- Root cause: Falta de process de triage de vulnerabilidades; herramientas fragmentadas.
- Impacto: Recursos gastados en vulnerabilidades bajas, críticas sin remediar.

4.3 Correlación Inter-Modular

Consistencia Vertical:

Ejemplo de inconsistencia detectada:

- Módulo A.8 (Gestión de cambios): L3 ✓
- Módulo D.9 (Incident response workflow): L1 ✗

Análisis: "Si cambios están gestionados (L3), debería existir workflow IR automático; gap sugiere silos entre Change Mgmt y SOC. Recomendación: integrar SIEM con CAB."

Impacto de Brechas Correlacionadas:

Si Risk Management (B) es L2 pero Compliance (F) reclama L3, significa:

- Cumplimiento es aspiracional, no basado en riesgo medido.
- Auditoría podría cuestionar rigidez de controles vs beneficio.

5. CÁLCULO DE MÉTRICAS

5.1 Métricas de Madurez por Dominio

Fórmula General:

$$\text{Score Dominio} = (\sum \text{Respuesta_Score}) / N \text{ Preguntas}$$

Si $\text{Score} < 30$ (L0-L1): Madurez INCIPIENTE
Si $30 \leq \text{Score} < 50$ (L1-L2): Madurez BÁSICA
Si $50 \leq \text{Score} < 70$ (L2-L3): Madurez OPERATIVA (Target NIS2)
Si $70 \leq \text{Score} < 85$ (L3-L4): Madurez AVANZADA
Si $\text{Score} \geq 85$ (L4-L5): Madurez LIDERAZGO

5.2 Métricas de Riesgo Residual

Basado en FAIR:

$$\text{Riesgo Residual} = \text{Loss Event Frequency} \times \text{Loss Magnitude}$$

Si no se tiene FAIR, usar escala cualitativa:

Riesgo Crítico (Rojo): Impacto alto $\times$ Probabilidad alta $\rightarrow$ acción inmediata
Riesgo Alto (Naranja): Impacto alto $\times$ Probabilidad media $\rightarrow$ acción 30 días
Riesgo Medio (Amarillo): Impacto medio $\times$ Probabilidad alta $\rightarrow$ acción 90 días
Riesgo Bajo (Verde): Impacto bajo $\times$ Probabilidad baja $\rightarrow$ aceptable

5.3 Métricas de Cumplimiento Regulatorio

NIS2 Readiness Index:

$$\text{NIS2RI} = (\sum \text{Medidas_Score}) / 10 \text{ Medidas}$$

Si NIS2RI < 50: NO LISTO (riesgo sanciones)

Si $50 \leq \text{NIS2RI} < 70$: EN PROGRESO

Si $\text{NIS2RI} \geq 70$: LISTO para auditoría 2026

España obligatoriedad: 18 oct 2024 (vigor)

Auditoría esperada: 2026-2027

5.4 Métricas de ROI/Efectividad

Training ROI Proxy:

$$\text{Training_Effectiveness} = (\% \text{ Incidentes detectados internamente} / \% \text{ Total incidentes}) \\ \times (1 - \text{Phishing_Click_Rate})$$

Si < 20%: Training bajo impacto

Si 20-40%: Training moderado impacto

Si > 40%: Training alto impacto

Pentesting ROI Proxy:

$$\text{Pentest_ROI} = (\sum \text{Vulnerabilidades_Críticas_Remediadas} / \sum \text{Halladas_Pentesting}) \times 100$$

Target: >80% (mayoría hallazgos se remedia)

Si <50%: Desconexión entre descubrimiento y remediación

6. GENERACIÓN DE REPORTES

6.1 Reporte Ejecutivo (1-2 páginas)

Contenido:

ENCUESTA INTEGRAL CIBERSEGURIDAD

Organización: XYZ Corp

Fecha: 15 enero 2026

Período Evaluado: 2025

SCORE GLOBAL: 56/100 (L2-L3, Madurez Básica-Operativa)

HALLAZGOS CLAVE:

✓ Fortalezas (3-5):

- SIEM operativo con reglas correlación (D.1, L3)
- Pentesting anual establecido (C.1, L3)
- Políticas documentadas (A.1, L3)

x Brechas Críticas (3-5):

- FAIR cuantificación ausente → Riesgo en € desconocido (B.13, L1)
- NIS2 notificación sin validación → Riesgo compliance (F.3, L1)
- Training sin medición efectividad → ROI opaco (E.5, L1)

! Riesgos Sistémicos (2-3):

- Fragmentación: Cambios (A.8, L3) vs Incident Response (D.9, L1) → gaps en flow
- Debilidad training: 51% aware training (vs 90.1% pentesting) → gap cultural

RECOMENDACIONES TOP 3:

1. Implementar FAIR para cuantificación riesgo (90 días, €15k) → Score B: 52-65
2. Validar NIS2 readiness con tabletop exercise (30 días, €5k) → Score F: 62-75
3. Integrar SIEM con workflow IR automation (60 días, €30k) → Score D: 58-72

TARGET 2026: Score 70+ (L3 completo, NIS2-ready)

6.2 Reporte Técnico Detallado (5-10 páginas)

Estructura:

20. Resumen Ejecutivo (1 p.)
21. Metodología (1 p.)
22. Resultados por Módulo (4-6 p.):
23. Gráfico radar (6 módulos)
24. Tabla scores
25. Hallazgos específicos
26. Brechas vs target
27. Riesgos Residuales (1-2 p.)
28. Roadmap de Mejora (1-2 p.)
29. Apéndice: Respuestas detalladas, evidencia, contactos

6.3 Visualización de Datos

Gráficos Recomendados:

30.

Radar Chart (6 módulos):

Vertex: A (Governance), B (Risk), C (Pentesting), D (SIEM), E (Training), F (Compliance)

Valor: Score 0-100

Líneas: Actual vs Target vs Industry Benchmark

31.

Heat Map (Preguntas vs Módulos):

Rojo (L0-L1): Crítico

Naranja (L2): Mejorar

Amarillo (L2-L3): Transición

Verde (L3+): Fortaleza

32.

Waterfall Chart (Score Actual vs Target):

Actual: 56

+Governance improvements: +5

+Risk quantification: +8

+Training acceleration: +5

Target: 74

33.

Timeline Roadmap:

Q1 2026: Quick wins (+5 puntos)

Q2 2026: Baseline compliance (+10 puntos)

Q3-Q4 2026: Advanced maturity (+10 puntos)

Target 2027: L4 en críticos

Radar Chart (6 módulos):

Vertex: A (Governance), B (Risk), C (Pentesting), D (SIEM), E (Training), F (Compliance)

Valor: Score 0-100

Líneas: Actual vs Target vs Industry Benchmark

Heat Map (Preguntas vs Módulos):

Rojo (L0-L1): Crítico

Naranja (L2): Mejorar

Amarillo (L2-L3): Transición

Verde (L3+): Fortaleza

Waterfall Chart (Score Actual vs Target):

Actual: 56

+Governance improvements: +5

+Risk quantification: +8

+Training acceleration: +5
Target: 74

Timeline Roadmap:

Q1 2026: Quick wins (+5 puntos)
Q2 2026: Baseline compliance (+10 puntos)
Q3-Q4 2026: Advanced maturity (+10 puntos)
Target 2027: L4 en críticos

7. ROADMAP DE MEJORA

7.1 Priorización de Iniciativas

Matriz de Impacto vs Esfuerzo:

Alto Impacto	Bajo Esfuerzo QUICK WINS - NIS2 tabletop (30d) - SIEM rule tuning	Alto Esfuerzo STRATEGIC BETS - FAIR implementation (90d) - Training platform upgrade
Bajo Impacto	MONITOR - Minor policy updates	AVOID - Legacy system deep dive

7.2 Plan de Acción por Fase

FASE 1: Quick Wins (Q1 2026, 0-90 días)

Iniciativa	Dueño	Esfuerzo	Impacto	Score Δ
NIS2 Tabletop Exercise	CISO	5 d	+15 puntos F	+1.5
SIEM rule tuning	SOC	10 d	+8 puntos D	+0.8
Policy awareness training	HR	5 d	+5 puntos E	+0.5
Total		20 d		+2.8 – 58.8

FASE 2: Baseline Compliance (Q2 2026, 90-180 días)

Iniciativa	Dueño	Esfuerzo	Impacto	Score Δ
FAIR implementation	Risk Mgmt	60 d	+12 puntos B	+2.4
Incident response workflow automation	CISO + SOC	45 d	+10 puntos D	+2.0
Training effectiveness measurement	HR	30 d	+8 puntos E	+1.2
Total		135 d		+5.6 – 64.4

FASE 3: Advanced Maturity (Q3-Q4 2026, 180+ días)

Iniciativa	Dueño	Esfuerzo	Impacto	Score Δ
Supply chain security program (SBOM, SCA)	AppSec	90 d	+10 puntos B	+2.0
Red team program	CISO	60 d	+8 puntos C	+1.2
Continuous training & gamification	HR	90 d	+10 puntos E	+1.5
Advanced UEBA deployment	SOC	120 d	+8 puntos D	+1.6
Total		360 d		+6.3 → 70.7

7.3 Estimación de Presupuesto

FASE 1 (Quick Wins):

- Consultant tabletop: €5k
- SIEM tuning (internal): €0
- Training development: €2k
- TOTAL: €7k

FASE 2 (Baseline):

- FAIR training & tooling: €15k
- SOAR integration: €30k
- Training platform: €25k
- TOTAL: €70k

FASE 3 (Advanced):

- Supply chain tools (SCA, SBOM): €40k
- Red team program (annual): €50k
- UEBA platform: €60k
- Gamification platform: €20k
- TOTAL: €170k

PRESUPUESTO TOTAL: €247k (spread 2026-2027)

8. SEGUIMIENTO Y EVOLUCIÓN

8.1 Cadencia de Re-Evaluación

Recomendación:

- Anual: Encuesta completa (mismo proceso).
- Trimestral: Mini-review de módulos críticos (especialmente D, E, F en 2026).
- Mensual: Tracking de métricas operativas (MTTD, phishing rate, patch SLA).

8.2 Dashboard de Seguimiento

Indicadores a Monitorear:

KPI	Baseline	Target 2026	Frecuencia
Score Global	56	70	Trimestral
MTTD (Crítico)	48h	<24h	Semanal
MTTR (Crítico)	90d	30d	Semanal
Phishing Click Rate	18%	<5%	Mensual
Training Completion	72%	95%	Mensual
NIS2 Readiness	45%	100%	Trimestral

8.3 Integración en Gobernanza

Comité de Seguridad Meetings:

Agenda mensual del Comité debe incluir:

- Status de Roadmap (% completación):
 - FAIR implementation: 40% (on track)
 - SOAR integration: 20% (at risk - vendor delay)
 - Training platform: 60% (ahead)
- KPI dashboard (gráficos de trending)
- Risk escalations (si métricas fuera de banda)
- Hallazgos auditoría externa (si aplica)
- Benchmark externo (si disponible - peers, industria)

8.4 Lecciones Aprendidas

Después de Encuesta, Documentar:

- ¿Qué asunciones eran incorrectas?
- ¿Qué módulos fueron más/menos fáciles de evaluar?
- ¿Qué evidencia faltó?
- ¿Cómo mejorar próxima encuesta?

Ejemplo:

Lección: Módulo D (SIEM) requería datos técnicos muy específicos que el CISO no tenía.
Acción futura: Incluir SOC lead directamente en respuesta D, no solo CISO.

Lección: FAIR (B.13) es concepto que requería explicación previa; 30% no entendían pregunta.

Acción futura: Pre-workshop de 1h sobre FAIR antes de responder módulo B.

APÉNDICE: TEMPLATE DE PLAN DE ACCIÓN

INICIATIVA: [Nombre]

ID: [Código, ej: B.13-001]

OBJETIVO: Implementar FAIR cuantificación de riesgo

ALINEACIÓN:

- Módulo: B (Risk Management)
- Métrica: B.13 (FAIR methodology)
- Score improvement: 52 → 65 (target L3)
- Regulatory: NIS2 preparación

DESCRIPCIÓN:

Adoptar metodología FAIR (Factor Analysis of Information Risk) para cuantificar riesgo en términos monetarios (€).

ALCANCE:

- 5 riesgos críticos top
- Loss Event Frequency (LEF) × Loss Magnitude (LM)
- Monte Carlo simulation para distribuciones

EQUIPO:

- Líder: Director de Riesgos
- Involucrados: CISO, Finanzas, Ops
- Facilitador externo: FAIR Institute certified consultant

HITOS:

- Semana 1-2: Training FAIR (internal team)
- Semana 3-6: Análisis escenarios de riesgo
- Semana 7-8: Modeling & simulation
- Semana 9-10: Review y presentación

PRESUPUESTO:

- Consultant: €8k (40 horas × €200/h)
- Software (Monte Carlo tool): €4k (annual license)
- Training materials: €1k
- Total: €13k

SUCCESS CRITERIA:

- ✓ 5 riesgos críticos cuantificados en €
- ✓ Modelo FAIR documentado y reproducible
- ✓ Score B.13 = L3 validado
- ✓ Presentación ejecutiva completada

RIESGOS:

- Falta de datos históricos → Mitigation: usar expert judgment + distribuciones conservadoras
- Resistencia interna a "pensar en dinero" → Mitigation: training cultura risk, case studies

DEPENDENCIAS:

- Necesario acceso a financial data (para LM estimation)
- Coordinación con Finance (para cost of incidents históricos)

STATUS: [Plan, In Progress, At Risk, Closed]

CONCLUSIÓN

Esta guía metodológica convierte una encuesta de 70 preguntas en un **programa de transformación estructurado**. El objetivo no es score perfecto, sino viaje de mejora con ritmo claro, presupuesto justificado, y ownership establecido.

La honestidad inicial (responder con LO-L2 donde sea cierto) es la base del roadmap creíble. Adelante.

FIN DE LA GUÍA METODOLÓGICA